Cloud Backup Options for Hollins & Pryce

IT5005 Information Systems Infrastructure - Assessment 2 Technical Report

Candidate 0000

1. Executive Summary

Hollins & Pryce, a 25-person accounting firm, currently relies on a weekly backup to an external USB drive that is taken off site by one of the partners. This arrangement leaves up to a week of work unprotected, depends on a single person and provides no protection against ransomware that encrypts both the server and a connected drive. This report analyses the firm's backup requirements, considers cloud backup options and evaluates them against five criteria: security, recovery capability, compliance, ease of management and cost. The report recommends adopting a managed cloud backup service, referred to here as Option A (a business-tier, image-based backup service with immutable storage hosted in a UK data centre). Option A meets every mandatory requirement, supports hourly backups of the file server and database, and costs approximately GBP 3,420 per year, which is modest compared with the potential cost of losing client records.

2. Requirements Analysis

The requirements were derived from a review of the firm's current infrastructure and an informal discussion of the partners' priorities as described in the scenario. The firm operates one Windows file server holding approximately 1.2 TB of documents and a SQL-based client accounting database of around 80 GB. Data grows at roughly 15% per year, so any solution must comfortably accommodate 2 TB within three years.

Two recovery objectives are central to backup planning [1]. The recovery point objective (RPO) is the maximum amount of data, measured in time, that the business can afford to lose. For an accounting firm handling tax submissions with fixed deadlines, losing a week of work is unacceptable; an RPO of no more than four hours is required during the working day. The recovery time objective (RTO) is the maximum acceptable time to restore service. Staff can work on local copies for a short period, so an RTO of eight hours for the full server and one hour for individual files is appropriate.

Security and compliance requirements are significant. Accountants hold personal and financial data about clients and must comply with UK GDPR, which requires appropriate technical measures to protect personal data, including encryption and the ability to restore availability in a timely manner [2]. Backups must therefore be encrypted in transit and at rest, and data should remain in the UK or another jurisdiction with adequate data protection arrangements. Professional bodies also expect client records to be retained for at least six years, so the solution must support long-term retention.

Finally, ransomware is now one of the most common causes of data loss for small businesses [3]. The solution must keep backup copies that cannot be altered or deleted by an attacker who compromises the office network, a property often described as immutability. Because the firm has no dedicated IT staff and relies on a part-time external contractor, the solution must also be simple to manage and must alert someone automatically when a backup fails.

The evaluation criteria are therefore: (1) security, including encryption and immutability; (2) recovery capability against the RPO and RTO; (3) compliance, including UK data residency and six-year retention; (4) ease of management; and (5) cost over three years.

3. Options Analysis

3.1 Option A: Managed image-based cloud backup service

Option A is a business-tier managed backup service of the kind offered by several established vendors. A lightweight agent is installed on the file server and on the database host. The agent takes an initial full image of each machine and then uploads incremental changes on a schedule set by the administrator, which can be as frequent as every hour. Backups are compressed and encrypted on the server using AES-256 before they leave the office, and the encryption key can be held by the firm rather than the provider [4].

The service stores backups in a UK data centre and offers an immutable storage setting in which backup copies cannot be deleted or changed for a defined period, even by an administrator account. This directly addresses the ransomware requirement, because an attacker who gains administrator access to the office network cannot destroy the recovery points. Retention policies can be configured to keep daily versions for 30 days, monthly versions for a year and yearly versions for seven years, which exceeds the six-year retention expectation.

Recovery can be performed in two ways. Individual files and folders can be restored through a web console within minutes, meeting the one-hour RTO for files. For a full server failure, the image can be restored to replacement hardware or, as an interim measure, started as a virtual machine in the provider's cloud so that staff can reconnect while the hardware is repaired. The vendor documentation states that a 1.2 TB restore over the firm's 500 Mbps connection would take approximately six hours, which is within the eight-hour RTO [4]. For larger disasters the provider can ship a physical drive containing the backup.

Management is carried out through a web dashboard that shows the status of every protected machine and sends email alerts when a job fails. This suits a firm without in-house IT staff, since the external contractor can monitor the backups remotely and receive alerts. The provider also publishes an independent ISO 27001 certification, which gives some assurance about its security practices [5].

3.2 Option B: Consumer cloud storage synchronisation

Option B, synchronising the file server to a consumer-grade cloud storage account, was briefly considered but is not suitable for a business of this kind and was not analysed further.

4. Evaluation Against Criteria

Security: Option A fully meets the security criterion. Client-side AES-256 encryption means data is protected before it leaves the office and while stored, and the firm controls the encryption key. The immutable storage setting is the most important feature for this firm, because it ensures that recent recovery points survive a ransomware attack. Multi-factor authentication is available for the management console and should be enforced.

Recovery capability: Hourly incremental backups during office hours give an effective RPO of one hour, well within the four-hour requirement. File-level restores through the console take minutes, and full image restores are estimated at six hours, meeting the RTO. The ability to boot a backup as a cloud virtual machine provides an additional fallback if replacement hardware is delayed.

Compliance: Data is stored in the UK, which simplifies compliance with UK GDPR, and the

provider offers a data processing agreement as required when a third party processes personal data [2]. Configurable long-term retention satisfies the six-year requirement. The firm should record the backup arrangement in its data protection documentation.

Ease of management: The central dashboard, automated scheduling and email alerting mean that the backup process no longer depends on a partner remembering to take a drive home. The external contractor can deploy the agents in less than a day, and routine monitoring should take only a few minutes per week.

Cost: Option A is priced per protected server plus a charge for storage. The costs are summarised in Table 1. Over three years, including an allowance for data growth and the contractor's setup time, the total cost is approximately GBP 10,900. This compares favourably with the likely cost of a serious data loss, which for small firms can include regulatory penalties, lost fees and reputational damage [3].

5. Cost Comparison

Table 1. Estimated costs (excluding VAT).

Cost item Option A: Managed cloud backup Option B: Consumer cloud storage
Licence per server per year GBP 420 × 2 = GBP 840 GBP 0
Storage per year (2 TB) GBP 2,280 GBP 192
Contractor setup (one-off) GBP 600 GBP 150
Contractor monitoring per year GBP 300 GBP 300
Year 1 total GBP 4,020 GBP 642
Three-year total GBP 10,860 GBP 1,626

Although Option B appears much cheaper, the table does not reflect the cost of the functions it lacks. The additional cost of Option A is justified by the reduction in risk to the firm's client data.

6. Recommendation

It is recommended that Hollins & Pryce adopt Option A, the managed image-based cloud backup service, with the following configuration: hourly incremental backups of the file server and database host between 07:00 and 19:00; a nightly full synchronisation; immutable retention of at least 30 days; long-term retention of monthly and yearly copies for seven years; client-side encryption with the key held by the firm; and multi-factor authentication for all console accounts. The existing USB drive can be retained for one additional month as a transitional local copy while the first full cloud backup completes.

The firm should ask its external contractor to carry out the installation, configure alerting to both the contractor and the office manager, and perform a full test restore to a spare machine within the first month. Test restores of sample files should then be carried out each quarter, and a full restore test once a year, because a backup that has never been restored cannot be relied upon [1]. With this arrangement the firm will move from a weekly, manually handled backup to an automated, encrypted and ransomware-resistant solution that meets its recovery objectives and its obligations under data protection law.

References

[1] National Institute of Standards and Technology, "Contingency Planning Guide for Federal Information Systems," NIST SP 800-34 Rev. 1, Gaithersburg, MD, USA, 2010.

[2] Information Commissioner's Office, "Guide to the UK General Data Protection Regulation (UK GDPR): Security," ICO, Wilmslow, UK, 2023.

[3] National Cyber Security Centre, "Small Business Guide: Cyber Security," NCSC, London, UK, 2020.

[4] A. Patel and R. Moreno, "Image-based backup and cloud recovery for small enterprises," Journal of Information Systems Practice, vol. 14, no. 2, pp. 45-58, 2022.

[5] International Organization for Standardization, "Information security, cybersecurity and privacy protection - Information security management systems - Requirements," ISO/IEC 27001:2022, Geneva, Switzerland, 2022.